

Análisis de Ciberseguridad

Asignatura: Electiva Ciberseguridad - 1ª entrega (Análisis y Diseño Seguro)

Proyecto: Plataforma Web Educación Vial IMSJ

1. Amenazas digitales identificadas

#	Amenaza	Explicación del riesgo para este proyecto
1	Inyección SQL	El login administrativo usa cédula y contraseña, y el dashboard permite crear y modificar noticias, materiales y preguntas frecuentes. Si el backend construye consultas concatenando esos datos, una entrada manipulada podría alterar la consulta, permitir el acceso sin credenciales válidas o leer, modificar y eliminar información de la base de datos.
2	XSS almacenado	El personal del IMSJ carga texto, enlaces y otros datos que luego se muestran en el frontend público. Si ese contenido se guarda y se presenta sin validación, sanitización o codificación de salida, un valor malicioso podría ejecutar código en el navegador de cada ciudadano que consulte la publicación.
3	Robo de credenciales y ataques de fuerza bruta	El acceso al panel se realiza con cédula y contraseña (RF1). Un engaño al personal, una contraseña débil o una gran cantidad de intentos automatizados podría permitir que una persona ajena ingrese al dashboard y actúe como usuario administrativo.
4	Fallas de control de acceso	El proyecto separa al público general del personal IMSJ (RNF1). Si esa separación se aplica solo en la interfaz y no se verifica en cada operación del backend, un usuario no autorizado podría invocar directamente funciones de creación, edición, publicación o eliminación de contenido.

2. Mapa de riesgos

Componente del sistema	Amenaza(s) asociada(s)	Impacto técnico	Impacto sobre usuarios
Login administrativo (RF1)	Inyección SQL; robo de credenciales; fuerza bruta	Omisión de la autenticación, acceso a una cuenta administrativa y ejecución de acciones con permisos del personal IMSJ.	Un integrante del personal podría sufrir la suplantación de su identidad y quedar asociado en el historial a cambios que no realizó.
Carga de contenidos (noticias, materiales y preguntas frecuentes)	XSS almacenado; fallas de control de acceso; carga de archivos inseguros	Publicación o modificación no autorizada de información, almacenamiento de contenido malicioso y pérdida de integridad de los datos.	La ciudadanía podría recibir información falsa, desactualizada o maliciosa desde un sitio que identifica como oficial.
Consulta pública (frontend-publico)	XSS almacenado; exposición de contenido no publicado	Ejecución de código en el navegador y visualización de contenidos que todavía no deberían ser públicos.	Los visitantes podrían ser redirigidos, ver contenido manipulado o acceder antes de tiempo a publicaciones internas o no aprobadas.
Base de datos	Inyección SQL; acceso no autorizado	Lectura, alteración o eliminación de usuarios administrativos, contenidos y registros del historial de acciones.	Podrían exponerse cédulas u otros datos vinculados a los usuarios administrativos, perderse información pública o dejar de estar disponible el servicio.

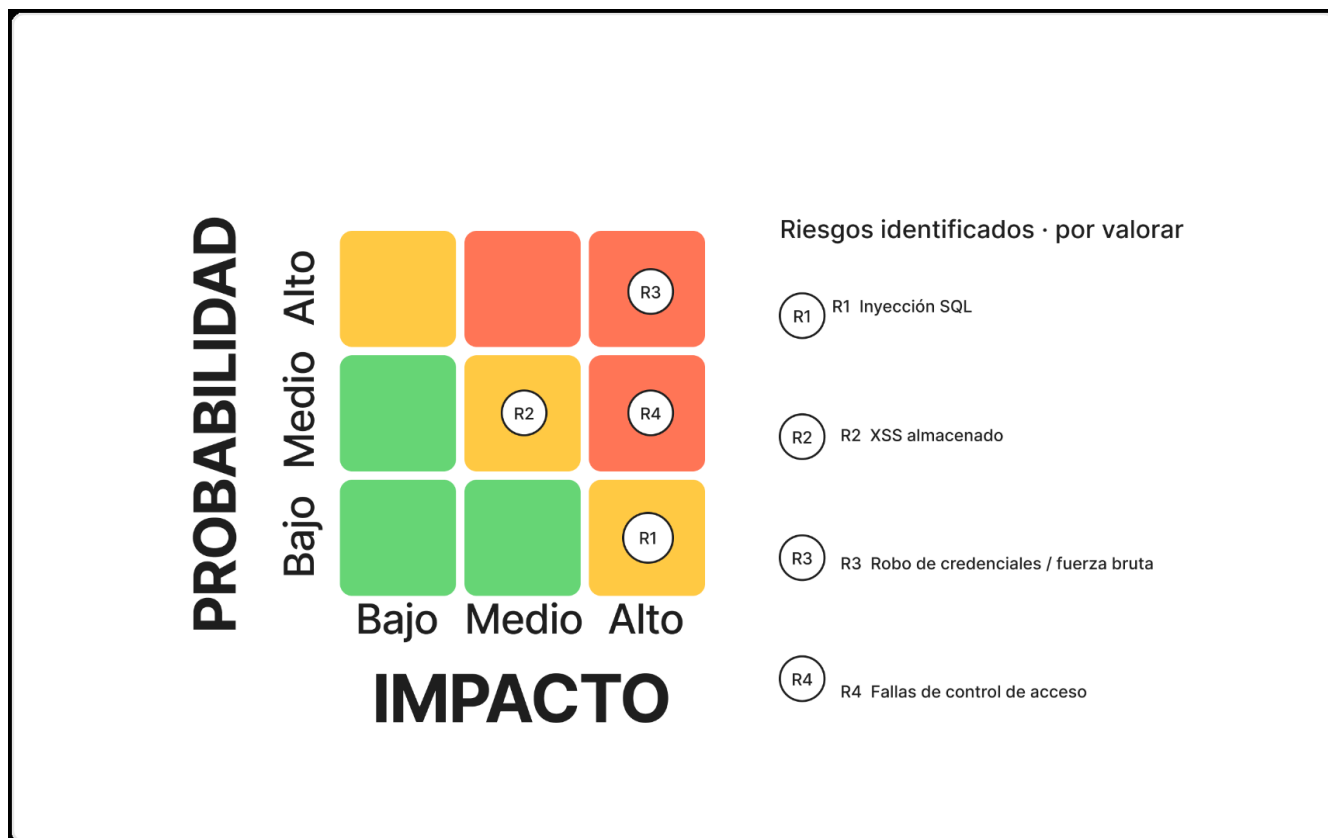


Figura 1. Matriz de riesgos del proyecto: probabilidad frente a impacto.

3. Buenas prácticas de seguridad aplicables

Práctica	Aplicación concreta en este proyecto
Validación de entradas	Para cumplir RNF2, el backend debe validar todos los datos recibidos antes de procesarlos o almacenarlos: campos obligatorios, tipo, longitud, formato y valores permitidos. Las consultas a la base de datos deben ser parametrizadas y, al mostrar contenido en los frontends, se debe aplicar codificación de salida o sanitización según el contexto. La validación del navegador sirve para orientar al usuario, pero no sustituye la validación del backend.
Hashing de contraseñas	Las contraseñas del personal IMSJ no deben guardarse en texto plano ni mediante cifrado reversible. Como propuesta de diseño, se utilizará bcrypt mediante una biblioteca mantenida, con salt individual gestionado por la propia implementación. En el login se comparará la contraseña ingresada con el hash almacenado, sin recuperar nunca la contraseña original.
Control de roles y permisos	Para cumplir RNF1, el backend debe comprobar la autorización en cada operación. El público solo podrá consultar contenidos que correspondan al sitio público, mientras que las operaciones de crear, editar, publicar o eliminar requerirán una sesión válida de personal IMSJ. Ocultar botones en el frontend administrativo no se considerará un control de seguridad suficiente.
Protección de datos personales	Para cumplir RNF4, se almacenarán únicamente los datos necesarios para autenticar e identificar las acciones del personal. La comunicación entre los frontends y la API deberá usar HTTPS; las credenciales de servicios y de base de datos se mantendrán fuera del código; y el acceso a usuarios, copias de respaldo e historial administrativo quedará restringido.
Registro de acciones administrativas	En relación con RNF3 y con el alcance definido en el charter, cada creación, modificación, publicación o eliminación deberá registrar como mínimo el usuario responsable, la acción, la fecha y hora y el elemento afectado. El historial debe estar protegido para que un usuario común no pueda modificarlo ni eliminarlo desde las funciones normales del dashboard.
Gestión segura de archivos	El proyecto contempla materiales en PDF, imágenes y videos, además de imágenes asociadas a noticias. El backend deberá aceptar solo los tipos previstos, comprobar extensión y tipo real del archivo, limitar el tamaño, generar nombres de almacenamiento seguros e impedir que los archivos cargados se ejecuten como código.

4. Referencias consultadas

Documentación interna del proyecto

- [Project Charter - Proyecto Educación Vial IMSJ](#)
- [Documento de Requisitos](#)
- [Concepción y documentación general del proyecto](#)
- [Descripción y responsabilidades del backend](#)

Fuentes de seguridad

- [OWASP - SQL Injection](#)
- [OWASP - Cross Site Scripting Prevention Cheat Sheet](#)
- [OWASP - Authentication Cheat Sheet](#)
- [OWASP - Authorization Cheat Sheet](#)
- [OWASP - Input Validation Cheat Sheet](#)
- [OWASP - Password Storage Cheat Sheet](#)
- [OWASP - Logging Cheat Sheet](#)
- [OWASP - File Upload Cheat Sheet](#)